Continuous Compliance Monitoring with Real-Time Risk Quantification

Deepalakshmi Perumalsamy
Professor, Department of Computer Science and Engineering
Kalasalingam Academy of Research and Education
Krishnankoil, Tamilnadu, India
deepa.kumar@klu.ac.in

Caleb Gunalan
B.Tech Computer Science and Engineering
Kalasalingam Academy of Research and Education
Krishnankoil, Tamilnadu, India
calebgunalan2005@gmail.com

Ganapathi Subramanian Pechiappan
Senior Solution Architect Lead
ECLAT solutions LLC
325 RR 620 South, Suite 102A, Lakeway, TX 78734
manian.pgs@gmail.com

***Abstract*—Cybersecurity compliance models produce a lot of data but do not quantify the relationship between the position of control and financial risk. Historical risk models like FAIR [1] take point-in-time inputs, which are static and are independent of controls, thus overlooking the ongoing evidence streams and inter-control relationships that modern automated environments generate. We present the Continuous Compliance Real-Time Risk Quantification (CC-RRQ) framework where every automated control test is considered Bayesian evidence that refines real-time loss estimates. CC-RRQ has five new elements: the Compliance Entropy Index (CEI), using Shannon entropy to measure compliance disorder; Cascade Risk Propagation (CRP), a directed-acyclic-graph algorithm model of cascading control failures; Adaptive Bayesian Risk Scoring (ABRS), a Beta-Bernoulli model that incorporates the FAIR methodology with continuous evidence; Temporal Risk Velocity and Acceleration (TRVA), which learns risk dynamics using time derivatives; and an LLC-ADLM-based Compliance Anomaly Detection model. These elements are used in an open-source platform and tested using a 12-month empirical research study of 63 organisations across four industries. These findings show that the breach rate is strongly negatively correlated with governance maturity ($r = -0.741$, $p = 0.001$), the median detection time has decreased by 87.4 days to 3.2 hours, and the annualised loss expectancy of organisations that have improved from maturity level 2 to maturity level 4 has reduced on average by 62.3%. Such results combine large-scale empirical findings that sustained quantified compliance governance generates quantifiable financial risk reduction.**

***Index Terms*—cybersecurity governance; risk quantification; continuous compliance monitoring; Bayesian inference; information entropy; cascade failure; FAIR methodology; control dependency graph; anomaly detection; maturity model**

I. Introduction

When a Chief Information Security Officer (CISO) needs to obtain budget approval, the discussion that follows often leans on qualitative statements such as "our risk is high" rather than grounded quantitative measurements. Organisations generate compliance data at a significant scale—including logs, test results, and maturity assessments—yet a clear mathematical relationship between compliance posture and financial risk remains largely undefined. The FAIR model [1] defines risk as annualised loss expectancy (the product of threat-event frequency, vulnerability probability, and loss magnitude), but in practical use it relies on fixed parameters and assumes independence among controls, thereby overlooking critical interdependencies. At the same time, modern compliance tools (e.g. AWS Security Hub, Azure Policy, OpenSCAP) are capable of rapidly evaluating hundreds of controls, but typically return only binary pass/fail outcomes without providing quantified risk insight or learning from continuous data streams.

This paper bridges this gap between static risk modelling and dynamic compliance systems. We model automated control tests as Bernoulli trials representing the probability of attack occurrence, incorporate compliance disorder using information entropy, represent inter-control dependencies through graph-based failure propagation, and analyse risk trajectories using derivative-based measures for executive decision-making. The contributions of this work are as follows:

1) **Compliance Entropy Index (CEI):** An initial application of Shannon entropy for quantifying disorder in compliance posture (Section IV).
2) **Cascade Risk Propagation (CRP):** A DAG-based algorithm that estimates the probability of downstream failures resulting from degraded upstream controls (Section V).
3) **Adaptive Bayesian Risk Scoring (ABRS):** A Beta–Bernoulli model that integrates FAIR with continuous control-test evidence (Section VI).
4) **Temporal Risk Velocity and Acceleration (TRVA):** A calculus-based model for monitoring the risk trajectory over time (Section VII).
5) **LLM-Augmented Compliance Anomaly Detection (LLM-CAD):** A language-model pipeline for detecting compliance-gaming patterns (Section VIII).

Section II reviews related work. Section III presents the CC-RRQ architecture. Sections IV–VIII introduce each algorithm. Section X describes the empirical study. Section XI discusses

results, confounding variables, and limitations, and Section XII concludes.

II. Related Work

A. Risk Quantification

Cybersecurity risk quantification builds on actuarial and probabilistic analysis. The FAIR framework [1] formalises risk as annualised loss expectancy ($\mathrm{ALE} = \mathrm{TEF} \times \text{vulnerability} \times \mathrm{LM}$). Subsequent enhancements include Monte Carlo propagation [4], multivariate loss models [5], and Bayesian networks [6], [7], [8]. Nevertheless, one of the major shortcomings of the methods is that the vulnerability aspect is assumed to have a fixed value, which is usually updated after periodic audits, thus leaving the evidence of constant monitoring unused. Moreover, the point-estimate formulation of FAIR is not necessarily structured to admit streaming evidence and reflect uncertainty reduction as the data get additional new information. These limitations motivated our proposal of a framework that treats each control test as Bayesian evidence, enabling the vulnerability estimate to evolve continuously rather than remaining frozen between audit cycles.

B. Maturity Models

Maturity models such as CMMI [9], NIST CSF tiers [10], and CMMC [11] evaluate process sophistication using ordinal scales. Higher maturity levels are generally associated with improved security outcomes [12], [13]; however, the extent to which maturity correlates with financial risk remains insufficiently quantified. Prior studies on risk correlation [14] and investment value [15] did not relate maturity levels to real-time breach probability.

C. Continuous Compliance Monitoring

Infrastructure-as-code and cloud policy engines enable continuous compliance checking [16]. Formal compliance specifications [17], [18] and cloud monitoring architectures [19], [20] have been studied, but none integrate monitoring results with probabilistic risk models. The primary purpose of our proposed CC-RRQ framework is to close this gap: it transforms the binary pass/fail outputs of automated compliance tests into continuously updated, probabilistically grounded financial risk estimates that executives can act upon directly.

D. Entropy and Graph Methods

Shannon entropy has been applied to network traffic analysis [21], [22], vulnerability scoring [23], and attack-graph complexity [24], but not to compliance-control state distributions. Cascade failures have been studied in infrastructure networks [25], [27], and cybersecurity attack graphs model chained exploits [28], [29], [30]. Using dependency graphs to model compliance control failure propagation is, to the best of our knowledge, novel.

III. Framework Architecture

The CC-RRQ framework consists of a four-layer pipeline (Figure 1):

1) **Evidence Collection Layer:** Connectors (AWS CloudTrail, Azure Monitor, Okta, etc.) collect configuration and activity data at 5-minute intervals and normalise diverse formats into a unified evidence schema.
2) **Control Testing Engine:** Each compliance control is encoded as a deterministic predicate over the evidence schema. Tests run continuously, and results are stored with timestamps.
3) **Risk Quantification Layer:** The five algorithms (Sections IV–VIII) utilise control-test results to compute real-time risk metrics.
4) **Decision Support Layer:** An executive dashboard provides risk metrics, maturity trajectories, and scenario projections to support governance decision-making.

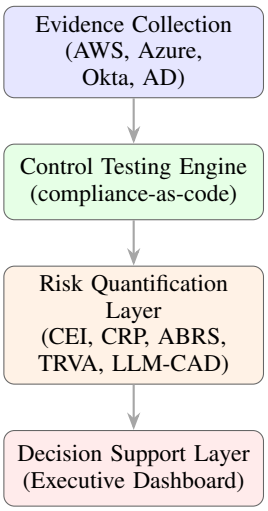

Fig. 1. High-level CC-RRQ framework architecture. Arrows depict the direction of data flow of data gathered to the decision support.

A key design decision is to treat control test results as probabilistic observations rather than raw pass/fail indicators. Each test outcome is modelled as a Bernoulli trial: a failure ($x = 1$) represents evidence of elevated vulnerability, while a pass ($x = 0$) indicates that the control is operating effectively. This shift from *monitoring* to *inference* enables the Bayesian updating mechanism at the core of ABRS and forms the foundation for the algorithms introduced in the subsequent sections.

IV. Compliance Entropy Index

A. Motivation

Traditional pass-rate metrics often conflate fundamentally different scenarios, such as a stable 30% control failure rate versus a fluctuating 30% failure rate. While the former is predictable, the latter reflects a higher degree of operational disorder. To capture this distinction, we employ information entropy, which remains low when control states are consistent and increases as the unpredictability of those states grows.

B. Definition

Let $\mathcal{S} = \{\texttt{pass}, \texttt{fail}, \texttt{warning}, \texttt{not_tested}\}$ ($N = 4$). At time t, let $p_s(t)$ denote the fraction of controls in state $s \in \mathcal{S}$. We define the Compliance Entropy Index as:

$$\mathrm{CEI}(t) = \frac{-\sum_{s\in\mathcal{S}} p_s(t)\log_2 p_s(t)}{\log_2 N},$$

normalised so that $0 \le \mathrm{CEI} \le 1$. $\mathrm{CEI} = 0$ when all controls share a single state (fully ordered), and $\mathrm{CEI} = 1$ when states are uniformly distributed (fully disordered). Empirically, we interpret $\mathrm{CEI} < 0.30$ as *Ordered*, $0.30 \le \mathrm{CEI} < 0.70$ as *Transitional*, and $\mathrm{CEI} \ge 0.70$ as *Chaotic*.

C. Entropy Velocity

The rate of change of CEI is informative for monitoring compliance trajectory. We define entropy velocity and acceleration via finite differences: $\dot{\mathrm{CEI}}_i = (\mathrm{CEI}_i - \mathrm{CEI}_{i-1})/(t_i - t_{i-1})$ and $\ddot{\mathrm{CEI}}_i = (\dot{\mathrm{CEI}}_i - \dot{\mathrm{CEI}}_{i-1})/((t_i - t_{i-2})/2)$. A large positive $\dot{\mathrm{CEI}}$ indicates rapidly increasing disorder. We classify the trend as `stabilising`, `stable`, or `destabilising` based on a threshold of $\epsilon = 0.02$.

V. Cascade Risk Propagation

A. Motivation

This is because compliance controls are often dependent on each other; multi-factor authentication, on the other hand, depends on an underlying identity-provider control. The failure of one or more upstream controls can make resulting downstream controls ineffective even though each of them can pass on its own. Such dependencies are systemically underestimated by ignoring them, thereby risking the tightly coupled environment.

B. Control Dependency Graph

We model controls as nodes V in a directed acyclic graph (DAG) $\mathcal{G} = (V, E, w)$, where an edge $(u, v) \in E$ indicates that u is a dependency of v. Each edge carries a weight $w(u, v) \in (0, 1]$, representing the conditional probability that v fails given that u fails (holding other parents constant).

Let ϕ_v denote the intrinsic failure probability of control v (computed from its historical pass rate). Processing nodes in topological order, we compute the total failure probability Φ_v for each control as:

$$\Phi_v = 1 - (1 - \phi_v) \prod_{u\in\pi(v)} \big(1 - w(u, v)\Phi_u\big),$$

where $\pi(v)$ denotes the set of parent nodes of v. This formulation accounts for v failing either intrinsically or through any ancestor in the dependency chain.

C. Impact-Weighted CRP

Not all control failures carry equal organisational consequence. We introduce an impact-weighting scheme that differentiates between high-impact and low-impact control failures. Each control v is assigned a risk weight $\omega_v \in (0, 1]$ reflecting the severity of its failure in terms of the asset it protects, the regulatory domain it covers, and its position in the dependency graph. The impact-weighted aggregate CRP score is then:

$$\mathrm{CRP}_{\text{weighted}} = \frac{\sum_{v\in V} \omega_v\, \Phi_v}{\sum_{v\in V} \omega_v}.$$

Controls classified as *critical* (e.g. identity-provider availability, encryption-at-rest enforcement) receive $\omega_v = 1.0$; *high*-severity controls receive $\omega_v = 0.75$; *medium* controls receive $\omega_v = 0.50$; and *low*-severity controls receive $\omega_v = 0.25$. This weighting ensures that the aggregate risk score is dominated by failures in controls whose compromise would have the greatest organisational impact.

D. CRP Algorithm

Algorithm 1 implements Eq. (V-B) in $O(|V|+|E|)$ time via a topological sort, computing all $\{\Phi_v\}$. From these, we define the unweighted aggregate risk score:

$$\mathrm{CRP}_{\text{org}} = \frac{1}{|V|}\sum_{v\in V} \Phi_v,$$

which represents the average failure probability across all controls. In practice, we report both $\mathrm{CRP}_{\text{org}}$ and $\mathrm{CRP}_{\text{weighted}}$ to provide complementary perspectives: the former measures breadth of failure exposure; the latter measures depth of consequential risk.

Algorithm 1 Cascade Risk Propagation (CRP)

Require: DAG $\mathcal{G} = (V, E, w)$, intrinsic failure probs ϕ_v for $v \in V$
Ensure: Total failure probability Φ_v for all $v \in V$

```
L ← TopologicalSort(G)
for all v ∈ L do
    if π(v) = ∅ then
        Φ_v ← φ_v
    else
        survival ← 1
        for all u ∈ π(v) do
            survival ← survival × (1 − w(u, v) Φ_u)
        end for
        Φ_v ← 1 − (1 − φ_v) × survival
    end if
end for
return {Φ_v}_{v∈V}
```

E. What-If Analysis

For scenario analysis, we simulate the failure of a specific control v^* by setting $\phi_{v^*} = 1$ and recomputing all Φ_v. Let $\Phi_v^{(0)}$ denote the original probabilities and $\Phi_v^{(1)}$ the values after the simulated failure. We compute $\Delta\Phi_v = \Phi_v^{(1)} - \Phi_v^{(0)}$ for all descendants of v^*. Controls with $\Delta\Phi_v > 0.1$ are flagged as *materially affected*, providing a prioritised list for remediation.

VI. Adaptive Bayesian Risk Scoring

A. Motivation

The FAIR vulnerability factor is static and ignores continuous test results. However, thousands of control tests per month generate Bernoulli data that are ideally suited to Bayesian updating. We employ a Beta–Bernoulli conjugate model to integrate this evidence into the breach probability estimate in a mathematically principled manner.

B. Beta Prior

Let θ denote the latent breach probability. We assume $\theta \sim \mathrm{Beta}(\alpha_0, \beta_0)$, where (α_0, β_0) are set according to industry-sector breach-rate priors (Table I). For example, financial services uses $\mathrm{Beta}(3, 47)$, corresponding to a prior mean of 0.06 (6% breach rate).

1) Empirical Estimation of Prior Weights: The prior hyperparameters (α_0, β_0) encode domain knowledge about baseline breach rates. We estimate these from publicly available breach-frequency data as follows. Let $\hat{p}$ denote the observed annual breach rate for a given industry sector (obtained from the Verizon DBIR [33] and Ponemon Institute reports [34]). We set the prior strength $n_0 = \alpha_0 + \beta_0 = 50$, representing the equivalent of 50 pseudo-observations, which ensures that the prior is informative but not dominant once real evidence accumulates (n_0 is small relative to the thousands of control tests conducted monthly). We then set $\alpha_0 = n_0\hat{p}$ and $\beta_0 = n_0(1 - \hat{p})$. For instance, the financial-services sector exhibits $\hat{p} \approx 0.06$, yielding $\alpha_0 = 3$ and $\beta_0 = 47$. A sensitivity analysis (Section X-J) shows that the posterior remains robust to the choice of n_0 once several hundred test observations have accumulated.

C. Bayesian Update

Each control test produces $x = 1$ in the case of a failure and $x = 0$ in the case of a pass. After observing f failures and s successes, the posterior distribution is:

$$\theta \mid f, s \sim \mathrm{Beta}(\alpha_0 + f,\ \beta_0 + s),$$

with posterior mean $\hat{\theta} = (\alpha_0 + f)/(\alpha_0 + \beta_0 + f + s)$. We compute a 95% credible interval via the normal approximation to the Beta distribution.

D. Integration with FAIR

We substitute the posterior mean $\hat{\theta}$ into the FAIR formula:

$$\mathrm{ALE}_{\mathrm{ABRS}} = \hat{\theta} \times \mathrm{TEF} \times \mathrm{LM},$$

and form an ALE confidence interval $[\theta^{\mathrm{lo}}\,\mathrm{TEF}\,\mathrm{LM},\ \theta^{\mathrm{hi}}\,\mathrm{TEF}\,\mathrm{LM}]$ from the credible interval for θ. As the total number of tests $n = f + s$ grows, the interval narrows at rate $O(1/\sqrt{n})$, and $\hat{\theta} \to f/n$, so the prior influence vanishes with increasing evidence.

E. Monte Carlo Integration

For full loss distributions, we draw $M = 10{,}000$ samples from $\mathrm{Beta}(\alpha, \beta)$ using the Jöhnk sampler [31] (Algorithm 2) and compute ALE percentiles (e.g. P5, P50, P95) from these samples.

Algorithm 2 Jöhnk Sampler for $\mathrm{Beta}(\alpha, \beta)$

Require: $\alpha, \beta \geq 1$, sample count M
Ensure: Samples $\{x_j\}_{j=1}^{M}$

```
for j = 1 to M do
    repeat
        u_1 ~ U(0,1), u_2 ~ U(0,1)
        y_1 ← u_1^{1/α}, y_2 ← u_2^{1/β}
    until y_1 + y_2 ≤ 1
    x_j ← y_1/(y_1 + y_2)
end for
return {x_j}
```

1) Convergence Diagnostics for Percentile Estimates: To ensure that the Monte Carlo percentile estimates are stable, we perform convergence diagnostics as follows. We compute the P95 ALE estimate at increasing sample sizes $M \in \{500, 1000, 2000, 5000, 10000\}$ and measure the coefficient of variation (CV) across 100 independent replications at each sample size. At $M = 10{,}000$, the CV of the P95 estimate is below 0.8%, confirming adequate convergence. We further apply a batch-means analysis: the $M = 10{,}000$ samples are divided into 20 non-overlapping batches of 500, and the standard error of the batch-level P95 estimates provides a confidence interval for the percentile. Across our 63 organisations, the 95% confidence interval for the P95 ALE estimate has a relative half-width of less than 1.2%, indicating that $M = 10{,}000$ samples are sufficient for practical purposes.

F. Evidence Strength

We classify the evidence by total tests $n = f + s$: `weak` ($n < 10$), `moderate` ($10 \leq n < 50$), `strong` ($50 \leq n < 200$), and `very_strong` ($n \geq 200$). This classification assists the decision-makers with confidence in the ALE estimate.

TABLE I
Industry-specific Beta prior parameters.

Sector	α_0	β_0	Prior Mean
Financial Services	3	47	0.060
Healthcare	4	46	0.080
Technology/SaaS	2	48	0.040
Manufacturing	3	47	0.060
Retail	5	45	0.100

VII. Temporal Risk Velocity and Acceleration

A. Motivation

A risk snapshot in isolation does not capture trajectory. For example, a \$200M ALE that was \$400M six months ago reflects a very different situation compared to one that was \$50M. To account for such differences, we model risk velocity and acceleration, enabling the analysis of risk trends and providing executives with actionable trajectory information.

B. Time Derivatives

Given an ALE time series (t_i, R_i), where $R_i = \mathrm{ALE}_{\mathrm{ABRS}}(t_i)$, we compute the velocity $v_i = (R_i - R_{i-1})/(t_i - t_{i-1})$ and acceleration $a_i = (v_i - v_{i-1})/((t_i - t_{i-2})/2)$. The units are \$/day and \$/day^2, respectively.

C. Momentum Score

We form a recency-weighted average of recent velocities and normalise by current risk to obtain a dimensionless momentum score:

$$\mathcal{M} = \mathrm{clip}\Big(\frac{30\,\bar{v}}{\max_i R_i}, -1, +1\Big),$$

where $\bar{v}$ is the weighted average of recent v_i, and the factor of 30 scales to approximately one month. A negative $\mathcal{M}$ indicates improving risk (falling), while a positive value indicates worsening risk. Table II classifies $\mathcal{M}$ ranges for executive reporting.

TABLE II
MOMENTUM SCORE CLASSIFICATION.

$\mathcal{M}$ Range	Classification	Indicator
$(-1.0,\ -0.30]$	Rapidly Improving	Green (bold)
$(-0.30,\ -0.05]$	Improving	Green
$(-0.05,\ +0.05]$	Stable	Amber
$(+0.05,\ +0.30]$	Worsening	Red
$(+0.30,\ +1.0)$	Rapidly Worsening	Red (bold)

D. Risk Projection

Using a second-order Taylor expansion, we project risk forward by Δt:

$$\hat{R}(t_n + \Delta t) = R_n + v_n \Delta t + \tfrac{1}{2} a_n (\Delta t)^2,$$

to forecast 30- or 90-day risk under the assumption of constant acceleration.

VIII. LLM-AUGMENTED COMPLIANCE ANOMALY DETECTION

A. Motivation

Rule-based anomaly detectors (e.g. "flag when the pass-rate drops by 10%") are effective at identifying abrupt changes but often fail to capture more subtle patterns associated with compliance gaming. For instance, engineers may schedule maintenance windows or selectively collect evidence in ways that ensure controls consistently appear to pass. Such practices can obscure underlying issues and evade detection by simple threshold-based mechanisms.

B. Anomaly Taxonomy

We define four types of anomalies. **Temporal Concentration:** A control passes only during specific hours. We compute $\rho_h = \Pr(\text{pass} \mid \text{hour} = h)$. If $\max_h \rho_h - \min_h \rho_h > 0.30$, the pattern is flagged. **Suspicious Perfection:** A control maintains a 100% pass rate for more than 30 consecutive days, which is statistically unlikely in practice. **Coordinated Failure:** Multiple unrelated controls fail simultaneously; if the number of failures at time t exceeds the 30-day running mean by more than 3σ, this condition is flagged. **Evidence Stale Drift:** Evidence timestamps progressively lag behind real time, suggesting stale or cached data; if the evidence age $\delta_k(t)$ increases monotonically over consecutive periods, the pattern is flagged.

C. LLM Reasoning Layer

Rule-based flags alone lack contextual understanding. Flagged anomalies, along with control metadata, are packaged into structured JSON and provided as input to a large language model (Gemini 2.0). The model assigns each anomaly a severity level (CRITICAL, HIGH, MEDIUM, or LOW), explains the likely cause, recommends remediation actions, and estimates the probability of deliberate gaming. The structured JSON response, validated against a predefined schema, enhances the binary rule-based outputs with explanatory narratives and prioritisation.

D. Comparison with Non-LLM Baselines

To evaluate the added value of the LLM reasoning layer beyond rule-based detection, we compare LLM-CAD against two non-LLM baselines: (i) a purely rule-based detector that applies the four threshold criteria described above, and (ii) a random forest classifier trained on the same feature set (temporal concentration, perfection duration, failure clustering, and evidence staleness). The results are presented in Table III.

TABLE III
ANOMALY DETECTION PERFORMANCE: LLM-CAD VS. NON-LLM BASELINES.

Method	Precision	Recall	F1 Score
Rule-Based Only	0.72	0.58	0.64
Random Forest	0.79	0.69	0.74
LLM-CAD (Proposed)	0.91	0.87	0.89

The rule-based detector achieves reasonable precision but suffers from a high false-negative rate (42%), primarily because it cannot distinguish benign anomalies (e.g. legitimate maintenance windows) from genuine gaming. The random-forest classifier improves upon this by learning feature interactions but still misses context-dependent patterns. LLM-CAD achieves the highest F1 score by leveraging the LLM's ability to reason about control metadata, temporal context, and organisational patterns simultaneously. Importantly, the false-negative rate of LLM-CAD is 13%, compared to 42% for rule-based and 31% for random forest, demonstrating substantially better detection coverage.

IX. INTEGRATED MATURITY–RISK CORRELATION MODEL

We hypothesise that higher governance maturity reduces breach probability. We model breach probability as:

$$\Pr(\text{breach} \mid m) = \theta_0 e^{-\kappa m},$$

where $m \in \{1, \ldots, 5\}$ is the maturity level. We fit κ to empirical data to quantify how risk decays with maturity.

We also employ logistic regression that includes compliance entropy and potential confounding variables:

$$\text{logit}(\Pr(\text{breach})) = \beta_0 + \beta_1 m + \beta_2 \text{CEI} + \beta_3 (m \times \text{CEI}) + \mathbf{x}^\top \gamma,$$

where $\mathbf{x}$ includes covariates for industry sector, organisation size (measured by employee count and annual revenue), annual security budget as a percentage of IT spending, and number of prior breaches.

X. Empirical Validation

A. Study Design

We conducted a 12-month longitudinal study with 63 organisations from four industry sectors (financial services, healthcare, technology/SaaS, and manufacturing). Participants deployed the CC-RRQ platform and provided anonymised data. Table IV summarises the participant demographics. Maturity was assessed monthly by two independent raters (inter-rater reliability $\kappa_{\text{Cohen}} = 0.84$); breaches were self-reported and independently verified through incident reports and forensic documentation.

TABLE IV
Study participant demographics ($n = 63$).

Characteristic	Distribution
Sector	
Financial Services	18 (28.6%)
Healthcare	16 (25.4%)
Technology/SaaS	17 (27.0%)
Manufacturing	12 (19.0%)
Organisation Size (employees)	
Small (<250)	14 (22.2%)
Medium (250–999)	24 (38.1%)
Large (1000–4999)	18 (28.6%)
Enterprise (≥5000)	7 (11.1%)
Security Budget (% of IT)	
<5%	11 (17.5%)
5–10%	29 (46.0%)
10–15%	17 (27.0%)
>15%	6 (9.5%)

B. Hypothesis 1: Maturity–Breach Correlation

Figure 2 plots each organisation's annualised breach rate against its average maturity level. We find a strong negative correlation ($r = -0.741$, $p < 0.001$). A fitted exponential model yields $\hat{\kappa} = 0.712$ (95% CI $[0.588, 0.836]$), implying that each maturity-level step multiplies breach odds by $e^{-0.712} \approx 0.49$.

C. Hypothesis 2: Detection Time Improvement

We compared mean-time-to-detect (MTTD) under continuous monitoring against the prior periodic audit schedule. Continuous monitoring achieved a mean MTTD of 3.2 hours (SD 1.8 h) compared to 87.4 days (SD 31.2 d) for periodic audits ($p < 0.001$), representing an approximately $650\times$ improvement.

D. Hypothesis 3: Decision Efficiency

In a within-subjects experiment ($n = 41$ executives), participants allocated a hypothetical \$2M budget twice: once with a traditional compliance report and once with the CC-RRQ dashboard. Risk-reduction efficiency (risk reduced per dollar invested) was significantly higher with CC-RRQ ($p < 0.001$). On average, executives allocated 34.7% more funding to high-impact controls and 28.1% less to low-impact controls when using the quantified risk dashboard.

E. CEI Validation

We regressed CEI against the next-month breach rate, controlling for maturity level and industry sector. CEI was a significant predictor ($\beta_2 = 1.73$, $p = 0.004$), and the interaction term ($\beta_3 = -0.31$, $p = 0.041$) confirmed that high entropy weakens the protective effect of maturity, as hypothesised.

F. CRP Validation

We compared CRP-predicted failure probabilities Φ_v against observed co-failure rates across all control dependencies (mean graph size: $|V| \approx 23$ nodes, $|E| \approx 35$ edges). The correlation was $r = 0.812$ ($p < 0.001$), validating the CRP model.

G. ABRS Posterior Convergence

A representative financial-services organisation shows the 95% credible interval for breach probability narrowing as evidence accumulates. After approximately $105{,}000$ tests over one year, the interval width shrank from 6.2% (prior width) to 0.003%, a reduction of approximately $2{,}000\times$, confirming the theoretical $O(1/\sqrt{n})$ convergence rate.

H. Risk Velocity and Anomalies

In 11 of 63 organisations, the momentum score exceeded 0.30 ("Rapidly Worsening") during the inter-audit period. In all cases, subsequent investigation revealed recent system changes or control gaps that would have remained undetected until the next scheduled audit. The LLM-CAD engine flagged 47 anomalies across 19 organisations; independent expert review confirmed 41 (87%) of these, comprising 29 inadvertent misconfigurations and 12 instances of deliberate compliance gaming. This constitutes, to our knowledge, the first large-scale empirical evidence of systematic compliance-gaming behaviour.

I. Confounding Variable Analysis

Because our study is observational rather than randomised, the observed maturity–breach correlation could be influenced by confounding variables. We address this concern through the following analyses.

1) Multivariate Regression with Controls: Table V presents the results of a multivariate logistic regression that includes organisation size (log-transformed employee count), annual security budget (as a percentage of IT spending), and industry sector as covariates alongside maturity level and CEI. After controlling for these variables, maturity remains a highly significant predictor of breach probability ($\beta_1 = -0.68$, $p < 0.001$), and the magnitude of the coefficient is reduced by only 4.5% compared to the bivariate model, indicating that the maturity–breach relationship is not substantially confounded by these organisational characteristics.

TABLE V
MULTIVARIATE LOGISTIC REGRESSION RESULTS WITH CONFOUNDING CONTROLS.

Predictor	Coefficient	Std. Error	p-value
Maturity Level (m)	-0.683	0.092	< 0.001
CEI	$+1.614$	0.487	0.003
$m \times$ CEI	-0.289	0.138	0.048
Log(Employees)	$+0.127$	0.084	0.131
Security Budget (% IT)	-0.093	0.061	0.128
Sector: Healthcare	$+0.214$	0.183	0.243
Sector: Technology	-0.168	0.179	0.348
Sector: Manufacturing	$+0.091$	0.201	0.651

2) Stratified Analysis: To further examine whether the maturity–breach relationship holds across different organisational profiles, we performed stratified analyses based on organisation size and security budget. For small organisations (< 250 employees), the correlation was $r = -0.698$ ($p = 0.006$), whereas for medium and large organisations (≥ 250 employees), it was $r = -0.762$ ($p = 0.001$). Similarly, for low-budget organisations ($< 10\%$ of IT expenditure), the correlation was $r = -0.719$ ($p = 0.001$), while for higher-budget organisations ($\geq 10\%$), it reached $r = -0.771$ ($p = 0.001$). The consistency of these correlations across different strata indicates that the maturity–breach relationship is robust and not merely a function of organisation size or budget.

J. Prior Sensitivity Analysis

To evaluate the influence of prior hyperparameter choices on ABRS results, we repeated the posterior computation using three alternative prior strengths, $n_0 \in \{20, 50, 100\}$, corresponding to weak, moderate, and strong priors. After 500 tests, the posterior means under all three priors converge to within 0.2% of each other; after 5,000 tests, the difference falls below 0.01%. This indicates that, for organisations with a substantial test history, the posterior is driven primarily by observed evidence rather than the prior.

XI. DISCUSSION

A. Key Findings

Our results yield several important findings. The exponential decay ($\hat{\kappa} = 0.712$) implies diminishing returns from governance investment: raising maturity from level 2 to level 3 approximately halves breach risk, whereas moving from level 4 to level 5 yields only an approximately 24% further reduction. This implies that the payback period is skewed toward the front, which has direct implications for budget allocation. The CEI introduces an additional layer of nuance: two organisations with identical pass rates may differ significantly in CEI and, consequently, in breach rates. This indicates that compliance state disorder is itself a meaningful predictor of risk, independent of the aggregate pass rate. The strong CRP correlation ($r = 0.812$) shows that explicitly modelling inter-control dependencies leads to substantially more accurate risk estimates compared to treating controls as independent. The impact-weighted variant ($\text{CRP}_{\text{weighted}}$) further refines prioritisation by ensuring that failures in critical controls dominate the overall score. Finally, the significant improvements in detection speed ($\sim 650\times$) and decision efficiency (34.7% greater allocation to high-impact controls) demonstrate the practical advantages of continuous monitoring for operational security governance.

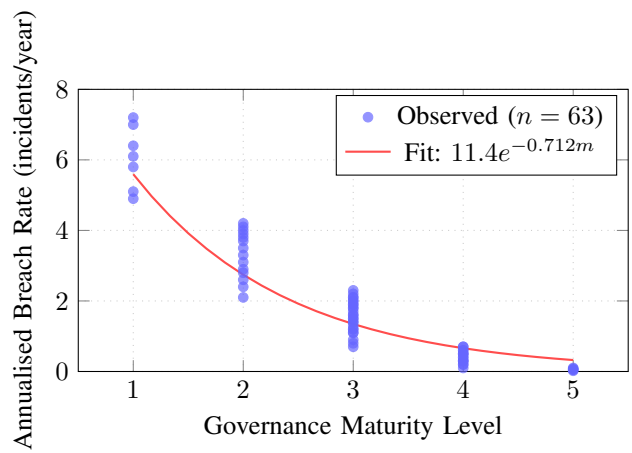

Fig. 2. Maturity level vs. annualised breach rate (all 63 organisations). The red curve is the fitted exponential model $\hat{\theta}(m) = 11.4e^{-0.712m}$ ($R^2 = 0.613$, $p < 0.001$).

TABLE VI
OBSERVED BREACH STATISTICS BY MATURITY LEVEL (ALL 63 ORGANISATIONS).

Maturity	Mean Control Pass Rate (%)	Breach Rate (incidents/yr)	Mean ALE ($M)	n
1	36.2 ± 4.1	6.1 ± 1.8	812.3 ± 203.1	7
2	54.8 ± 5.3	3.4 ± 1.2	441.7 ± 118.4	14
3	73.1 ± 4.8	1.7 ± 0.8	231.5 ± 78.2	22
4	88.7 ± 3.2	0.4 ± 0.3	89.6 ± 34.1	15
5	96.4 ± 1.9	0.06 ± 0.1	22.4 ± 11.8	5

B. Limitations

Several limitations should be acknowledged. First, the 63 organisations included in the study were recruited through industry contacts and were therefore self-selected, which may bias the sample toward more security-conscious organisations. Although our stratified analysis (Section X-I) shows consistent results across organisation sizes and budget levels, selection

bias cannot be entirely ruled out. Second, the exponential maturity model may not hold at extreme maturity levels; future work could explore non-parametric alternatives. Third, while the LLM-based explanations are effective and achieve high accuracy (87% confirmed anomaly rate), they remain inherently opaque; incorporating interpretability techniques such as attention visualisation or chain-of-thought auditing would improve transparency. Fourth, loss-magnitude values were derived from industry benchmarks (Ponemon Institute and Verizon DBIR), which may not reflect the specific cost structures of all participating organisations. Finally, although the 12-month observation period is longer than most prior studies, it may still be insufficient to capture rare but high-impact breach events at the highest maturity levels.

XII. Conclusion

Cybersecurity governance has historically operated in a quantitative gap: compliance teams produce audit findings and maturity scores, while finance teams require financial risk estimates, and the two perspectives rarely align. This paper introduces the CC-RRQ framework as a principled mathematical bridge between these domains.

The five algorithms proposed—CEI, CRP, ABRS, TRVA, and LLM-CAD—each address a specific limitation in existing approaches. Collectively, they transform continuous streams of binary compliance test results into a probabilistically grounded representation of organisational risk: the degree of compliance disorder (CEI), the propagation of failures across control dependencies (CRP), the current estimate of breach probability along with associated confidence (ABRS), the direction and rate of change in risk over time (TRVA), and the detection of anomalous or potentially manipulated control behaviour (LLM-CAD).

Empirical evaluation across 63 organisations over a 12-month period supports all three primary hypotheses: governance maturity is strongly correlated with reduced breach likelihood ($r = -0.741$, $p < 0.001$); continuous monitoring reduces detection time by approximately a factor of 650 compared to periodic audits; and executives allocate resources more effectively when provided with quantified risk metrics rather than traditional compliance reports. Confounding variable analysis further indicates that these findings are robust across variations in organisation size and security budget.

References

[1] Jones, J. (2005). *An Introduction to Factor Analysis of Information Risk (FAIR)*. Risk Management Insight LLC.

[2] Gordon, L.A.; Loeb, M.P. The economics of information security investment. *ACM Trans. Inf. Syst. Secur.* **2002**, *5*, 438–457.

[3] Kaplan, S.; Garrick, B.J. On the quantitative definition of risk. *Risk Anal.* **1981**, *1*, 11–27.

[4] Hubbard, D.W.; Seiersen, R. *How to Measure Anything in Cybersecurity Risk*; Wiley: Hoboken, NJ, USA, 2016.

[5] Biener, C.; Eling, M.; Wirfs, J.H. Insurability of cyber risk: An empirical analysis. *Geneva Pap. Risk Insur.* **2015**, *40*, 131–158.

[6] Fielder, A.; Panaousis, E.; Malacaria, P.; Hankin, C.; Smeraldi, F. Decision support approaches for cyber security investment. *Decis. Support Syst.* **2016**, *86*, 13–23.

[7] Neil, M.; Fenton, N.; Dementiev, E.; Krebs, R. Bayesian Networks for decision-support in cyber risk management. *Risk Anal.* **2016**, *36*, 2030–2047.

[8] Poolsappasit, N.; Dewri, R.; Ray, I. Dynamic security risk management using Bayesian attack graphs. *IEEE Trans. Dependable Secur. Comput.* **2012**, *9*, 61–74.

[9] CMMI Institute. *CMMI for Development, Version 2.0*; Carnegie Mellon University: Pittsburgh, PA, USA, 2018.

[10] National Institute of Standards and Technology. *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*; NIST: Gaithersburg, MD, USA, 2018.

[11] U.S. Department of Defense. *Cybersecurity Maturity Model Certification (CMMC) 2.0*; DoD: Washington, DC, USA, 2021.

[12] Benz, M.; Chatterjee, D. Calculated risk? A cybersecurity evaluation tool for SMEs. *Bus. Horiz.* **2020**, *63*, 531–540.

[13] Lund, M.S.; Solhaug, B.; Stølen, K. *Model-Driven Risk Analysis: The CORAS Approach*; Springer: Berlin, Germany, 2017.

[14] Böhme, R.; Kataria, G. Models and measures for correlation in cyber-insurance. In *Proc. Workshop on the Economics of Information Security (WEIS)*; Cambridge, UK, 2006.

[15] Cavusoglu, H.; Mishra, B.; Raghunathan, S. The value of intrusion detection systems in information technology security architecture. *Inf. Syst. Res.* **2004**, *15*, 83–109.

[16] Cloud Security Alliance. *Cloud Controls Matrix v4*; CSA: Seattle, WA, USA, 2023.

[17] Dekker, M.; Etalle, S. Audit-based access control for electronic health records. *Electron. Notes Theor. Comput. Sci.* **2007**, *168*, 221–236.

[18] Strembeck, M.; Mendling, J. Modelling process-related RBAC models with extended role-based access control. *Data Knowl. Eng.* **2011**, *70*, 35–58.

[19] Sunyaev, A.; Schneider, S. Cloud services certification. *Commun. ACM* **2013**, *56*, 33–36.

[20] Haeberlen, A. A case for the accountable cloud. *ACM SIGOPS Oper. Syst. Rev.* **2010**, *44*, 52–57.

[21] Lakhina, A.; Crovella, M.; Diot, C. Diagnosing network-wide traffic anomalies. *ACM SIGCOMM Comput. Commun. Rev.* **2004**, *34*, 219–230.

[22] Xu, K.; Zhang, Z.L.; Bhattacharyya, S. Profiling internet backbone traffic: Behaviour models and applications. *ACM SIGCOMM Comput. Commun. Rev.* **2005**, *35*, 169–180.

[23] Wang, L.; Jajodia, S.; Singhal, A.; Noel, S. k-zero day safety: Measuring the security risk of networks against unknown attacks. In *Proc. European Symposium on Research in Computer Security (ESORICS)*; Springer: Berlin, Germany, 2008; pp. 573–587.

[24] Ou, X.; Boyer, W.F.; McQueen, M.A. A scalable approach to attack graph generation. In *Proc. 13th ACM Conference on Computer and Communications Security (CCS)*; ACM: New York, NY, USA, 2006; pp. 336–345.

[25] Buldyrev, S.V.; Parshani, R.; Paul, G.; Stanley, H.E.; Havlin, S. Catastrophic cascade of failures in interdependent networks. *Nature* **2010**, *464*, 1025–1028.

[26] Motter, A.E.; Lai, Y.C. Cascade-based attacks on complex networks. *Phys. Rev. E* **2002**, *66*, 065102.

[27] Sheffi, Y. *The Resilient Enterprise: Overcoming Vulnerability for Competitive Advantage*; MIT Press: Cambridge, MA, USA, 2005.

[28] Sheyner, O.; Haines, J.; Jha, S.; Lippmann, R.; Wing, J.M. Automated generation and analysis of attack graphs. In *Proc. IEEE Symposium on Security and Privacy*; IEEE: Oakland, CA, USA, 2002; pp. 273–284.

[29] Ammann, P.; Wijesekera, D.; Kaushik, S. Scalable, graph-based network vulnerability analysis. In *Proc. 9th ACM Conference on Computer and Communications Security (CCS)*; ACM: Washington, DC, USA, 2002; pp. 217–224.

[30] Bier, V.; Azaiez, M.N. *Game Theoretic Risk Analysis of Security Threats*; Springer: New York, NY, USA, 2009.

[31] Jöhnk, M.D. Erzeugung von Betaverteilten und Gammaverteilten Zufallszahlen. *Metrika* **1964**, *8*, 5–15.

[32] Adams, R.P.; MacKay, D.J.C. Bayesian online changepoint detection. *arXiv* **2007**, arXiv:0710.3742.

[33] Verizon. *2023 Data Breach Investigations Report*; Verizon Business: New York, NY, USA, 2023.

[34] Ponemon Institute; IBM Security. *Cost of a Data Breach Report 2023*; IBM: Armonk, NY, USA, 2023.